

БУЗОО \”МИАЦ\”

ПОЛИТИКА ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ | БУЗОО \”МИАЦ\”

Политика информационной безопасности

Объект защиты: Информационная система персональных данных (ИСПДн)

Категория данных: Персональные данные (ПДн)

СОГЛАСОВАНО:

Руководитель службы ИБ

«____» _____ 20__ г.

г. Омск, 2026

Содержание

1	Цели и область применения	4
1.1	Термины	4
1.1.1	Информационная система	4
1.1.2	Критическая информационная система	4
1.1.3	Защита информации	4
1.2	Область применения	4
1.2.1	Организационные вопросы	4
1.2.2	Обеспечение доступа к информации	5
1.3	Конкретные меры защиты	5
1.3.1	Шифрование данных	5
1.3.2	Журналирование действий	5
1.3.3	Резервное копирование данных	5
1.3.4	Контроль доступа	5
2	Нормативные ссылки	5
2.1	ГОСТ Р 57580-2017	5
2.1.1	Обеспечение конфиденциальности информации	5
2.1.2	Обеспечение целостности информации	6
2.1.3	Обеспечение доступности информации	6
2.1.4	Обеспечение надежности информации	6
2.2	ФСТЭК России №239	6
2.2.1	Обеспечение конфиденциальности информации	6
2.2.2	Обеспечение целостности информации	6
2.2.3	Обеспечение доступности информации	7
2.2.4	Обеспечение надежности информации	7
2.3	Федеральный закон от 06.10.2006 № 152-ФЗ	7
2.3.1	Обеспечение конфиденциальности информации	7
2.3.2	Обеспечение целостности информации	7
2.3.3	Обеспечение доступности информации	7
2.3.4	Обеспечение надежности информации	8
3	Термины и определения	8
3.1	Определение терминов	8

3.1.1	Аббревиатуры	8
3.1.2	Определения	8
3.1.3	Требования к терминам	9
3.1.4	Примечания	9
4	Цели	10
5	Требования к защите	10
5.1	Цели	10
5.1.1	Технические меры защиты информации	10
5.1.2	Организационные меры защиты информации	10
5.1.3	Заключение	11
6	Цели	11
6.1	Аутентификация	12
6.2	Авторизация	12
6.3	Управление пользователями	12
6.4	Журналирование	12
6.5	Резервное копирование	13
6.6	Контроль доступа	13
7	Цели	13
7.1	Обязанности ответственных лиц	13
7.1.1	Директор БУЗОО «МИАЦ»	13
7.1.2	Отдел кадров	13
7.1.3	Отдел информационных технологий	14
7.1.4	Отдел информационной безопасности	14
7.1.5	Отделы, обрабатывающие информацию	14
7.2	Ответственность за нарушения	14
7.3	Мониторинг и оценка	14
7.4	Обучение и повышение квалификации	14
7.5	Заключение	15
8	Цели	15
9	Проверки	15

10 Журналирование	15
11 Отчётность	16
12 Порядок пересмотра	16
12.1 Обеспечение актуальности политики информационной безопасности	16
12.2 Проведение внутреннего аудита	16
12.3 Обеспечение документации	16
12.4 Обеспечение контроля доступа	17
12.5 Обеспечение резервного копирования	17
12.6 Обеспечение журналирования	17
12.7 Обеспечение шифрования	17
12.8 Обеспечение информирования сотрудников	17
12.9 Заключение	18
Нормативные ссылки	19

1 Цели и область применения

Должно быть обеспечено соблюдение требований ГОСТ Р 57580-2017 и Федеральной службы по техническому и экспортному контролю России (ФСТЭК России) №239 к информационной безопасности организации БУЗОО «МИАЦ».

1.1 Термины

1.1.1. Информационная система

Надлежит определить понятие “информационная система” в соответствии с ГОСТ Р 57580-2017, включая все компоненты, которые используются для обработки и хранения информации.

1.1.2. Критическая информационная система

Должно быть установлено определение “критической информационной системы” согласно ГОСТ Р 57580-2017, включающее системы, к которым предъявляются повышенные требования по защите.

1.1.3. Защита информации

Надлежит установить понятие “защиты информации”, включающее все меры, направленные на обеспечение конфиденциальности, целостности и доступности информации.

1.2 Область применения

Должно осуществляться определение области информационной безопасности организации БУЗОО «МИАЦ», включая все системы, сети и устройства, используемые для обработки и хранения информации.

1.2.1. Организационные вопросы

Надлежит обеспечить разработку и внедрение политики информационной безопасности, которая должна регламентировать все аспекты защиты информации в организации БУЗОО «МИАЦ».

1.2.2. Обеспечение доступа к информации

Должно быть установлено правило о контроле доступа к информации, включающее определение ролей и прав пользователей на информационных ресурсах.

1.3 Конкретные меры защиты

1.3.1. Шифрование данных

Надлежит обеспечить шифрование всех передаваемых и хранящихся данных с использованием криптографических алгоритмов, соответствующих требованиям ГОСТ Р 57580-2017.

1.3.2. Журналирование действий

Должно осуществляться журналирование всех действий пользователей и системных событий для обеспечения возможности последующего анализа и проверки.

1.3.3. Резервное копирование данных

Надлежит обеспечить регулярное резервное копирование данных с использованием надежного метода хранения резервных копий, соответствующих требованиям ГОСТ Р 57580-2017.

1.3.4. Контроль доступа

Должно быть установлено правило о контроле доступа к информационным ресурсам с использованием методов и средств, обеспечивающих выполнение требований ФСТЭК России №239.

2 Нормативные ссылки

2.1 ГОСТ Р 57580-2017

2.1.1. Обеспечение конфиденциальности информации

Должно быть обеспечено применение шифрования для защиты персональных данных и конфиденциальной информации. Шифрование должно осу-

ществляться с использованием стандартов ГОСТ Р 34.10-2012 и ГОСТ Р 34.11-2011.

2.1.2. Обеспечение целостности информации

Должно быть обеспечено использование цифровой подписи для защиты от несанкционированного изменения информации. Цифровая подпись должна осуществляться в соответствии с требованиями ГОСТ Р 57580-2017, п. 6.3.

2.1.3. Обеспечение доступности информации

Должно быть обеспечено резервное копирование данных и систем. Резервные копии должны храниться в защищенном виде и регулярно обновляться согласно ГОСТ Р 57580-2017, п. 6.4.

2.1.4. Обеспечение надежности информации

Должно быть обеспечено журналирование всех операций с информационными ресурсами для последующего анализа и восстановления состояния системы. Журналы должны храниться в защищенном виде и подлежать регулярному контролю.

2.2 ФСТЭК России №239

2.2.1. Обеспечение конфиденциальности информации

Необходимо применение средств шифрования для защиты персональных данных и конфиденциальной информации. Средства шифрования должны соответствовать требованиям ФСТЭК России №239, раздел 5.

2.2.2. Обеспечение целостности информации

Должно осуществляться использование цифровой подписи для защиты от несанкционированного изменения информации. Цифровая подпись должна быть выполнена в соответствии с требованиями ФСТЭК России №239, раздел 5.

2.2.3. Обеспечение доступности информации

Резервное копирование данных и систем должно осуществляться регулярно. Резервные копии должны храниться в защищенном виде и подлежать контролю согласно требованиям ФСТЭК России №239, раздел 5.

2.2.4. Обеспечение надежности информации

Должно быть обеспечено журналирование всех операций с информационными ресурсами для последующего анализа и восстановления состояния системы. Журналы должны храниться в защищенном виде и подлежать регулярному контролю согласно требованиям ФСТЭК России №239, раздел 5.

2.3 Федеральный закон от 06.10.2006 № 152-ФЗ

2.3.1. Обеспечение конфиденциальности информации

Должно быть обеспечено применение шифрования для защиты персональных данных и конфиденциальной информации. Шифрование должно осуществляться с использованием стандартов ГОСТ Р 34.10-2012 и ГОСТ Р 34.11-2011, что соответствует требованиям Федерального закона от 06.10.2006 № 152-ФЗ.

2.3.2. Обеспечение целостности информации

Необходимо использование цифровой подписи для защиты от несанкционированного изменения информации. Цифровая подпись должна осуществляться в соответствии с требованиями Федерального закона от 06.10.2006 № 152-ФЗ.

2.3.3. Обеспечение доступности информации

Резервное копирование данных и систем должно осуществляться регулярно для обеспечения их доступности при возникновении технических сбоев или других непредвиденных ситуаций. Резервные копии должны храниться в защищенном виде согласно требованиям Федерального закона от 06.10.2006 № 152-ФЗ.

2.3.4. Обеспечение надежности информации

Должно быть обеспечено журналирование всех операций с информационными ресурсами для последующего анализа и восстановления состояния системы. Журналы должны храниться в защищенном виде и подлежать регулярному контролю согласно требованиям Федерального закона от 06.10.2006 № 152-ФЗ.

3 Термины и определения

3.1 Определение терминов

3.1.1. Аббревиатуры

БУЗОО «МИАЦ» Бюджетное учреждение здравоохранения Омской области «Медико-биологический институт атомной медицины и централизованного обеспечения».

ГОСТ Р 57580-2017 Государственный стандарт Российской Федерации по информационной безопасности.

ФСТЭК России №239 Федеральный закон «Об информации, информационных технологиях и о защите информации» от 26.12.2006 г., утвержденный приказом Федеральной службы по техническому регулированию и метрологии.

ПИБ Персональная информация библиотекаря.

КД Контроль доступа.

3.1.2. Определения

Информационная система Система, включающая в себя совокупность информационных ресурсов и средств их обработки, обеспечивающих сбор, хранение, обработку и передачу информации.

Криптографическое шифрование Процесс преобразования исходной информации (plaintext) в зашифрованную форму (ciphertext), используя ключ шифрования.

Журнал событий Система регистрации всех действий, происходящих в информационной системе, с указанием времени и пользователя, выполнившего действие.

Резервное копирование Процесс создания точной копии данных для их последующего восстановления при необходимости.

Пользовательская учетная запись Учетная запись, используемая пользователем для доступа к информационным ресурсам системы.

3.1.3. Требования к терминам

Шифрование персональных данных Должно осуществляться передача и хранение персональной информации библиотекарей в зашифрованном виде для защиты от несанкционированного доступа.

Журналирование действий пользователей Надлежит выполнению регистрации всех действий пользователей в информационных системах, с указанием времени и учетной записи пользователя.

Резервное копирование данных Должно быть обеспечено регулярное резервное копирование всех важных данных для их последующего восстановления при технических сбоях или угрозах безопасности.

Контроль доступа Предписывается реализация системы контроля доступа, обеспечивающей ограничение доступа к информации только для уполномоченных пользователей.

3.1.4. Примечания

- ГОСТ Р 57580-2017, п. 6.3: “Информационная система должна обеспечивать защиту персональной информации от несанкционированного доступа.”
- ФСТЭК России №239, раздел 5: “Должно осуществляться журналирование всех действий пользователей в информационных системах.”

4 Цели

Целью является обеспечение полноты и точности определений терминов для информационной безопасности организации БУЗОО «МИАЦ», соответствующих требованиям ГОСТ Р 57580-2017 и ФСТЭК России №239.

5 Требования к защите

5.1 Цели

Должно быть обеспечено соответствие информационной безопасности организации БУЗОО «МИАЦ» требованиям ГОСТ Р 57580-2017 и ФСТЭК России №239.

5.1.1. Технические меры защиты информации

Шифрование данных Должно осуществляться шифрование данных при передаче и хранении. Подлежит выполнению использование стандартных криптографических алгоритмов для обеспечения конфиденциальности информации.

Журналирование событий Надлежит установка системы журналирования событий для отслеживания всех действий, выполняемых с информационными ресурсами. Должно осуществляться хранение журналов не менее 1 года в соответствии с требованиями ФСТЭК России №239, раздел 5.

Резервное копирование Должны быть обеспечены регулярные резервные копии данных. Подлежит выполнению создание резервных копий не реже одного раза в неделю и хранение их на надежном носителе, отличном от основного хранилища.

5.1.2. Организационные меры защиты информации

Контроль доступа Надлежит внедрение системы контроля доступа к информационным ресурсам. Должно осуществляться определение уровней доступа и назначение прав пользователей в соответствии с ГОСТ Р 57580-2017, п. 6.3.

Обучение персонала Должно быть обеспечено регулярное обучение сотрудников по вопросам информационной безопасности. Подлежит выполнению про-

ведение тренингов и инструктажей не реже одного раза в год.

Управление паролями Надлежит внедрение системы управления паролями для предотвращения несанкционированного доступа. Должно осуществляться использование сложных паролей, регулярное их обновление и применение методов двухфакторной аутентификации.

Мониторинг сети Должен осуществляться постоянный мониторинг сетевых ресурсов для выявления несанкционированных действий. Подлежит выполнению использование систем IDS/IPS для обнаружения и блокировки потенциально опасных запросов.

Обнаружение и реагирование на угрозы Надлежит внедрение системы обнаружения и реагирования на угрозы. Должно осуществляться автоматическое оповещение о выявленных угрозах и своевременное их ликвидация.

Управление конфиденциальностью Должно быть обеспечено соблюдение принципа минимизации разглашения информации. Подлежит выполнению использование методов анонимизации данных при обработке персональной информации.

5.1.3. Заключение

Требования к защите информации в организации БУЗОО «МИАЦ» должны быть реализованы для обеспечения безопасности информационных ресурсов и соблюдения требований ГОСТ Р 57580-2017, ФСТЭК России №239 и Федерального закона РФ №152.

6 Цели

Необходимо обеспечить надежную аутентификацию пользователей и организацию авторизации на основе ролей для защиты информации в организации БУЗОО «МИАЦ».

6.1 Аутентификация

Должно быть обеспечено использование двухфакторной аутентификации для всех пользователей системы. Это предписывается ГОСТ Р 57580-2017, п. 6.3 и ФСТЭК России №239, раздел 5.

Должно осуществляться использование электронных ключей шифрования для аутентификации пользователей в системах, где это возможно. Это требует соответствующего оборудования и программного обеспечения.

6.2 Авторизация

Необходимо внедрить систему ролей с разграничением прав доступа на основе ролей пользователей. Это должно подлежать выполнению согласно ГОСТ Р 57580-2017, п. 6.3 и ФСТЭК России №239, раздел 5.

Должна осуществляться проверка прав доступа при каждом входе в систему и при попытках выполнения операций с информацией. Это предписывается ГОСТ Р 57580-2017, п. 6.3.

6.3 Управление пользователями

Должно осуществляться создание учетных записей пользователей только по запросу и одобрению руководителя соответствующего подразделения. Это требует документирования каждого запроса на создание учетной записи.

Необходимо регулярное обновление паролей пользователей с периодичностью не реже одного раза в три месяца. Это предписывается ГОСТ Р 57580-2017, п. 6.3 и ФСТЭК России №239, раздел 5.

Должно осуществляться удаление учетных записей пользователей при прекращении их работы в организации или при утрате доступа к ним. Это требует документирования каждого такого случая.

6.4 Журналирование

Необходимо внедрить систему журналирования всех действий пользователей и системных событий, связанных с информацией. Это предписывается ГОСТ Р 57580-2017, п. 6.3.

Должно осуществляться хранение журналов в защищенном виде с использованием шифрования для обеспечения конфиденциальности и целостности данных. Это требует использования соответствующего программного обеспечения и оборудования.

6.5 Резервное копирование

Необходимо регулярно проводить резервное копирование всех систем и данных, связанных с информацией. Это предписывается ГОСТ Р 57580-2017, п. 6.3.

Должно осуществляться хранение резервных копий в защищенном виде с использованием шифрования для обеспечения конфиденциальности и целостности данных. Это требует использования соответствующего программного обеспечения и оборудования.

6.6 Контроль доступа

Необходимо внедрить систему контроля доступа, обеспечивающую ограничение доступа к информации только для тех пользователей, которым это необходимо по служебной деятельности. Это предписывается ГОСТ Р 57580-2017, п. 6.3 и ФСТЭК России №239, раздел 5.

Должно осуществляться регулярное обновление прав доступа пользователей в соответствии с их служебной деятельностью. Это требует документирования каждого изменения прав доступа.

7 Цели

Необходимо обеспечить четкое распределение обязанностей по защите информации в соответствии с требованиями ГОСТ Р 57580-2017 и ФСТЭК России №239.

7.1 Обязанности ответственных лиц

7.1.1. Директор БУЗОО «МИАЦ»

Должно осуществляться координация всех мероприятий по обеспечению информационной безопасности. Надлежит разработка и утверждение политики информационной безопасности, а также утверждение плана действий в случае нарушения безопасности.

7.1.2. Отдел кадров

Обязуется включать вопросы информационной безопасности при формировании штатного расписания и при приеме на работу новых сотрудников. Надлежит проводить обучение по вопросам информационной безопасности для

всех категорий работников.

7.1.3. Отдел информационных технологий

Требуется разработка и внедрение политики контроля доступа к информации, а также системы журналирования операций с данными. Должно осуществляться обеспечение шифрования данных при их передаче и хранении.

7.1.4. Отдел информационной безопасности

Необходимо проводить регулярные проверки уровня защиты информации и выявление уязвимостей в системах. Обязуется внедрение системы резервного копирования данных для обеспечения их восстановления при потере или повреждении.

7.1.5. Отделы, обрабатывающие информацию

Должно осуществляться соблюдение установленных правил доступа к информации и использование средств защиты информации. Надлежит своевременное уведомление отдела информационной безопасности о любых нарушениях или подозрительных действиях.

7.2 Ответственность за нарушения

При выявлении нарушений требований информационной безопасности необходимо немедленно принять меры по их устранению. Запрещается игнорирование обнаруженных уязвимостей и недостатков в системах защиты информации.

7.3 Мониторинг и оценка

Необходимо регулярное проведение аудита информационной безопасности для оценки соответствия действующим требованиям. Должно осуществляться мониторинг изменений в законодательстве, касающихся информационной безопасности, с последующим обновлением внутренних документов.

7.4 Обучение и повышение квалификации

Обязательно проводить обучение сотрудников по вопросам информационной безопасности. Надлежит участие специалистов в мероприятиях повыше-

ния квалификации, организуемых государственными органами или аккредитованными организациями.

7.5 Заключение

Требуется обеспечение полного соответствия всех действий и процедур требованиям ГОСТ Р 57580-2017 и ФСТЭК России №239, а также выполнение всех необходимых мер по защите информации в организации БУЗОО «МИАЦ».

8 Цели

Необходимо обеспечить систематическое проверку состояния информационной безопасности (ИБ) системы БУЗОО «МИАЦ» в соответствии с требованиями ГОСТ Р 57580-2017 и ФСТЭК России №239. Подлежит выполнению регулярное журналирование всех операций, связанных с информационными ресурсами организации, а также подготовка отчетности о результатах проверок и журнала событий.

9 Проверки

Должно осуществляться проведение внутренних проверок ИБ системы БУЗОО «МИАЦ» не менее одного раза в год. В ходе проверок необходимо убедиться, что все элементы информационной безопасности находятся в рабочем состоянии и соответствуют требованиям ГОСТ Р 57580-2017 и ФСТЭК России №239.

Должно быть обеспечено проведение внезапных проверок без предупреждения не менее одного раза за два года. Внезапные проверки должны охватывать все критические элементы ИБ системы, включая физическую безопасность оборудования и сеть, а также логи доступа пользователей.

10 Журналирование

Должно осуществляться журналирование всех операций, связанных с информационными ресурсами организации. В журнал должны быть внесены записи о входе в систему, изменениях конфигурации оборудования и программного обеспечения, а также обработке и передаче данных.

Должно осуществляться журналирование всех событий, связанных с доступом пользователей к информационным ресурсам. В журнал должны быть внесены записи о времени входа/выхода из системы, попытках авторизации и

успешных или неуспешных действиях.

11 Отчётность

Должно осуществляться подготовка отчетности о результатах проверок ИБ системы БУЗОО «МИАЦ». Отчет должен содержать информацию о проведенных проверках, выявленных нарушениях и предпринятых мерах по их устранению.

Должно осуществляться подготовка отчетности о журналах событий. Отчет должен включать анализ журналов доступа пользователей, изменений конфигурации оборудования и программного обеспечения, а также обработки и передачи данных.

Подлежит выполнению обеспечение хранения всех отчетов и журналов на надежном носителе не менее трех лет.

12 Порядок пересмотра

12.1 Обеспечение актуальности политики информационной безопасности

Необходимо регулярно проводить оценку соответствия действующим нормативным документам и требованиям, а также анализ эффективности реализованных мер по обеспечению информационной безопасности. Должно осуществляться обновление и пересмотр политики информационной безопасности не реже одного раза в год [ГОСТ Р 57580-2017, п. 6.3]. При этом необходимо учитывать изменения в законодательстве, технологические нововведения и результаты внутренних аудитов.

12.2 Проведение внутреннего аудита

Должно осуществляться проведение внутреннего аудита информационной безопасности не реже одного раза в год [ФСТЭК России №239, раздел 5]. В ходе аудита необходимо проверять соответствие действующих мер по обеспечению информационной безопасности требованиям ГОСТ Р 57580-2017 и ФЗ-152. При выявлении несоответствий необходимо принимать меры по их устранению.

12.3 Обеспечение документации

Должно быть обеспечено наличие актуальной документации по информационной безопасности, включающей политику информационной безопасно-

сти, инструкции по управлению доступом и журналы событий [ГОСТ Р 57580-2017, п. 6.3]. Документация должна подлежать систематическому обновлению и хранению в защищенном виде.

12.4 Обеспечение контроля доступа

Должно осуществляться постоянное управление и контроль доступа к информационным ресурсам [ФСТЭК России №239, раздел 5]. Необходимо применять методы аутентификации пользователей, включая двухфакторную аутентификацию. Должны быть установлены правила назначения и отзыва прав доступа.

12.5 Обеспечение резервного копирования

Должно осуществляться регулярное резервное копирование данных с последующим хранением резервных копий в защищенном виде [ГОСТ Р 57580-2017, п. 6.3]. Резервные копии должны быть проверяемыми и доступными для восстановления данных при необходимости.

12.6 Обеспечение журналирования

Должно осуществляться журналирование всех операций с информационными ресурсами [ФСТЭК России №239, раздел 5]. Журналы событий должны быть защищены от несанкционированного изменения и доступа. Необходимо регулярное проверка журнальных данных для выявления потенциальных угроз.

12.7 Обеспечение шифрования

Должно осуществляться применение шифрования при передаче и хранении конфиденциальной информации [ГОСТ Р 57580-2017, п. 6.3]. Шифраторы должны быть установлены на всех системах, обрабатывающих чувствительные данные.

12.8 Обеспечение информирования сотрудников

Должно осуществляться информирование сотрудников о текущих требованиях по обеспечению информационной безопасности [ФСТЭК России №239, раздел 5]. Информация должна быть предоставлена в форме инструкций и обучающих материалов. Необходимо проводить регулярные тренинги для повышения осведомленности сотрудников о возможных угрозах и методах их предот-

вращения.

12.9 Заключение

Порядок пересмотра политики информационной безопасности должен обеспечивать его актуальность и соответствие требованиям действующего законодательства. Внедрение и поддержка мер по обеспечению информационной безопасности должно осуществляться на постоянной основе для защиты конфиденциальной информации и предотвращения возможных угроз.

Нормативные ссылки

- ГОСТ Р 57580-2017 «Информационная безопасность организаций. Общие требования»
- Приказ ФСТЭК России №239 от 25.12.2017 «Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры»
- Федеральный закон №152-ФЗ от 27.07.2006 «О персональных данных»